SECTION 1

Manage identity, access, and governance



INSTRUCTOR
ALAN RODRIGUES

Microsoft Entra ID: The Identity Foundation



- **Microsoft Entra ID** is Microsoft's cloud-based identity and access management service. It provides the trusted identity system used to control access to Microsoft 365, Azure, enterprise applications, and other integrated cloud services.

- **Authentication** confirms who or what is requesting access. Users may authenticate with passwords, multifactor authentication, passwordless methods, certificates, or other supported credentials.

- **Authorization** determines what an authenticated identity is permitted to access. Permissions may be granted through application assignments, Microsoft Entra roles, Azure RBAC roles, groups, and access policies.

- Microsoft Entra ID provides a central identity provider. A single organizational identity can be used to access applications, devices, data, and cloud resources instead of maintaining separate credentials for every service.

EXAM FOCUS - Remember the difference: authentication verifies the identity; authorization determines the permitted actions and resources.

Why Organizations Use Microsoft Entra Groups



- **Groups** allow administrators to manage access collectively. Instead of assigning the sa permissions repeatedly to individual users, administrators assign access to a group an then manage the group's membership.

- **Groups can be used with applications**, licenses, administrative roles, and cloud resources. The exact capabilities depend on the group type, configuration, and target service.

- **Group-based management** improves consistency. Users performing the same job function can receive the same baseline access, reducing the risk of missing or inconsistent individual assignments.

- **Groups support least privilege**. A user should be added only to groups required for their current responsibilities and removed when their role or employment status changes.

EXAM FOCUS - When many users require the same access, prefer group -based assignment over assigning permissions separately to each user.

Microsoft Entra ID P1



- **Microsoft Entra ID P1** adds advanced identity and access management capabilities. It is commonly required when an organization needs policy-based access decisions rather than relying only on basic user authentication.
- **Conditional Access is a major P1 capability.** It operates as an if-then policy engine: if specified identities access selected resources under defined conditions, Microsoft Entra applies the configured access controls.
- **Conditional Access can evaluate sign-in context.** Policies can consider factors such as the user or group, target application, device platform, location, client application, and device state.
- **P1 supports dynamic group membership.** Membership rules can use user or device attributes to automate access and administrative processes as organizational information changes

EXAM FOCUS - Standard Conditional Access scenarios normally require Microsoft Entra ID P1. Policies based on calculated user risk or sign-in risk require the Identity Protection capabilities associated with P2.

Microsoft Entra ID P2



- **Microsoft Entra ID P2** extends the capabilities of P1 with advanced identity risk and privileged access controls. It is intended for organizations that need to detect potentially compromised identities, make risk-based access decisions, and reduce permanent administrative access.

- **Microsoft Entra ID Protection** analyzes identity and sign-in activity for suspicious behaviour. It records individual risk detections and provides reports for risky users, risky sign-ins, and the underlying risk detections that contributed to the assessment.

- **P2 also supports Microsoft Entra Privileged Identity Management (PIM)** which allows administrators to make users eligible for privileged roles and activate those roles only when required, for a limited period.

EXAM FOCUS - Associate Identity Protection, user risk, sign-in risk, and Privileged Identity Management with Microsoft Entra ID P2.

Azure RBAC: Authorization for Azure Resources



- **Azure role-based access control** is the authorization system for Azure resources. It determines which identities can access Azure resources, which operations they can perform, and the resources to which that access applies.

- **Azure RBAC is built on Azure Resource Manager** and is used to control access to resources such as subscriptions, resource groups, virtual machines, storage accounts, virtual networks, and Key Vaults.

- Access is granted by creating a role assignment. Azure evaluates the assigned role w an authenticated identity attempts to perform an operation on a resource.

- The objective is least-privilege access. An identity should receive only the permissions required for its responsibilities and only at the necessary resource scope.

EXAM FOCUS - Azure RBAC answers three questions: Who receives access? What can they do? Where can they do it?

The Three Elements of a Role Assignment



- **Security principal**—who receives access. This is the identity to which the permissions are assigned, such as a user, group, service principal, or managed identity.
- **Role definition**—what the identity can do. The role contains the permitted operations, such as viewing, creating, updating, deleting, or managing access to Azure resources
- **Scope**—where the permissions apply. The scope may be a management group, subscription, resource group, or an individual Azure resource.
- Azure combines the principal, role, and scope into a role assignment. Changing any o of these elements changes the access that is granted.

EXAM FOCUS - A role definition by itself does not grant access.
Access is granted only when the role is assigned to a principal at a scope.

Security Principals



- A user represents an individual identity. A role can be assigned directly to a user when the access requirement is specific to that person.
- A group represents multiple identities with a common access requirement. Assigning a role to a group is usually easier to manage than creating identical role assignments for several individual users.
- A service principal represents an application or automated workload. It allows the application to authenticate and receive Azure permissions without operating as a human user.
- A managed identity is an identity assigned to a supported Azure resource. Azure manages its underlying credentials, allowing applications to request tokens without storing client secrets or passwords in code.

EXAM FOCUS - When several employees require identical access, assign the role to a group. When an Azure -hosted workload requires access without stored credentials, use a managed identity.

Understanding Role Definitions



- A role definition is a collection of permissions. It identifies the Azure operations that a principal is allowed to perform, such as reading, creating, updating, or deleting resources.
- Azure provides built-in roles for common responsibilities. Administrators should first select the built-in role that most closely matches the required job function.
- Service-specific roles usually provide more precise access. For example, a workload that only needs to read blob data should receive Storage Blob Data Reader instead of a broader storage or administrative role.
- Custom roles can be created when no built-in role meets the requirement. A custom role should include only the required operations and should not be created merely to avoid reviewing the available built-in roles.

EXAM FOCUS - Choose the most specific built-in role that satisfies the requirement before considering Contributor, Owner, or a custom role.

Reader and Contributor



- Reader provides read-only control-plane access to Azure resources. A Reader can view resource configurations and properties but cannot create, update, or delete the resources.

- Reader does not automatically provide access to resource data. For example, viewing a storage account does not grant permission to read its blobs; a suitable data access role may also be required.

- Contributor can create and manage Azure resources. It provides broad resource management permissions at the assigned scope.

- Contributor cannot assign Azure RBAC roles. A Contributor can manage resources but cannot grant another identity access by creating role assignments.

EXAM FOCUS - Reader: view resources, no changes.
Contributor: manage resources but cannot assign roles.

Azure RBAC Scope Levels



- Scope defines the resource boundary for a role assignment. The assigned permissions can be used only within the selected scope and its applicable descendants.
- Management group is the broadest primary scope. A role assignment at this level can apply across the subscriptions and resources placed beneath that management group.
- Subscription scope applies across the subscription. Resources and resource groups within the subscription normally inherit role assignments made at this level.
- Resource group scope limits access to one resource group and its resources. It is usef when an administrator manages a particular workload or environment but does not require access to the entire subscription.
- Resource scope is the narrowest level. It limits the role assignment to an individual resource, such as one virtual machine, storage account, or Key Vault.

EXAM FOCUS - Permissions assigned at a higher scope are inherited by resources at lower scopes..

Microsoft Entra Roles



- Microsoft Entra roles provide administrative authorization within a tenant. They determine who can configure identities, directory objects, authentication, applications, security settings, and supported Microsoft services.
- Roles contain predefined administrative permissions. Instead of giving an administrator unrestricted access, the organization can select a built-in role that matches the administrator's responsibilities.
- Common role assignments include managing users, groups, applications, licenses, Conditional Access, authentication methods, security information, and administrative roles.
- Microsoft Entra roles should follow least privilege. Administrators should receive the least powerful role that allows them to complete the required administrative task.

EXAM FOCUS - Microsoft Entra roles control tenant and directory administration; they are not the same as Azure resource roles.

Microsoft Entra Roles Versus Azure RBAC



- Microsoft Entra roles manage the tenant and directory. They control operations involving users, groups, enterprise applications, authentication methods, Conditional Access, and other directory services.

- Azure RBAC roles manage Azure resources. They control access to subscriptions, resource groups, virtual machines, virtual networks, storage accounts, databases, and other Azure resources.

- The two authorization systems are separate. Assigning User Administrator or Applicati Administrator does not provide permission to create or modify Azure resources.

- Global Administrator does not automatically receive Azure resource permissions. However, a Global Administrator can elevate access to obtain a management rights across Azure subscriptions and management groups associated with the tenant.

EXAM FOCUS - Managing users normally requires a Microsoft Entra role; managing a virtual machine normally requires an Azure RBAC role.

Global Administrator



- Global Administrator provides the broadest administrative access. It can manage almo every aspect of Microsoft Entra ID and services that rely on Microsoft Entra identities.
- A Global Administrator can manage users, groups, applications, administrative roles, authentication settings, tenant-wide policies, and many connected Microsoft services.
- The role can elevate access to manage Azure role assignments at the root scope. This capability does not mean Azure resource access is automatically assigned.
- The role should be assigned only when a less privileged role cannot satisfy the requirement. Microsoft recommends assigning Global Administrator to fewer than five people.

EXAM FOCUS - Managing users normally requires a Microsoft Entra role; managing a virtual machine normally requires an Azure RBAC role.

User Administrator and Groups Administrator



- User Administrator manages user accounts. Responsibilities can include creating use updating user properties, assigning licences, managing groups, and resetting passwords for permitted users.

- User Administrator has restrictions around privileged identities. It cannot perform ever sensitive operation against every administrator, and it cannot manage MFA settings.

- Groups Administrator provides more focused group management permissions. It can create and manage groups, memberships, group settings, naming policies, and expiration policies.

- Groups Administrator can affect groups used by services such as Teams, SharePoint Outlook, and other Microsoft 365 workloads. Group changes can therefore alter acces beyond Microsoft Entra ID itself.

EXAM FOCUS - Manage users and permitted password resets → User Administrator.
Manage group configuration and membership only → Groups Administrator.

Understanding Authentication Methods



- Authentication methods define how users prove their identities. A method may support initial sign-in, multifactor authentication, self-service password reset, account recovery, or a combination of these scenarios.

- Administrators manage modern methods through the Authentication methods policy. Methods can be enabled for all users or targeted to selected groups.

- Not every method can be used for every purpose. For example, a passkey can provide primary authentication, while a software OATH code is normally used as an additional verification factor.

- Security strength differs between methods. Passkeys and certificate-based authentication are phishing-resistant, while one-time codes and telephone-based methods can be captured, relayed, or socially engineered.

EXAM FOCUS - Check whether the scenario requires primary authentication, MFA, SSPR, onboarding, recovery, or phishing resistance before choosing a method.

Microsoft Authenticator



- Microsoft Authenticator supports several authentication experiences. These include MFA notifications, OATH verification codes, passwordless phone sign-in, and passkeys.
- Push-based MFA sends a sign-in request to the registered mobile device. The user reviews the request and approves or denies it, with number matching helping the user verify the correct sign-in session.
- The app can generate time-based OATH codes without network connectivity. This provides an alternative when push notifications or mobile data are unavailable.
- Passwordless phone sign-in uses a key-based credential stored on the device. The user confirms the sign-in and unlocks the credential with the device PIN or biometric recognition.

EXAM FOCUS - Authenticator can perform several functions. Identify whether the question requires push MFA, offline verification codes, passwordless phone sign-in, or a passkey.

Authentication methods



- A Temporary Access Pass is an administrator-issued, time-limited passcode. It can be configured for one-time use or multiple sign-ins during its validity period.
- TAP is primarily used to bootstrap stronger authentication. A new user can use it to sig in and register a passkey, Microsoft Authenticator, FIDO2 security key, or Windows He for Business.
- Hardware OATH tokens are physical devices that display rotating codes. They are use for users who cannot carry a mobile phone or require an offline physical authenticator
- Email OTP sends a temporary code to a registered email address. The user enters the code to complete the supported verification or sign-in process.
- SMS can send a one-time verification code to a registered telephone number. It has supported MFA, SSPR, and SMS-based primary sign-in when enabled.

EXAM FOCUS - Select the method that satisfies both the user scenario and the required security strength —not merely the most familiar authentication method.

What Is Microsoft Entra PIM?



- Microsoft Entra Privileged Identity Management helps control privileged access to important resources. It provides time-based and approval-based activation instead of requiring administrators to hold powerful permissions continuously.

- PIM reduces standing privilege. A user can be approved as eligible for a role but receives its permissions only after completing the required activation process.

- PIM can enforce security controls before privileged access becomes active. These controls can include multifactor authentication, Conditional Access authentication context, business justification, ticket information, approval, and a limited activation period.

- PIM records privileged-access activity. Administrators can review assignments, activations, approvals, expirations, and changes to role settings.

EXAM FOCUS - A requirement for just-in-time, approval-based, or time-limited privileged access normally indicates Microsoft Entra PIM.

The Three Main Areas Managed by PIM



- PIM for Microsoft Entra roles governs administrative roles used to manage identities, applications, authentication, Conditional Access, and other tenant services.
- PIM for Azure resources governs Azure RBAC roles assigned at management group, subscription, resource group, or individual resource scope.
- PIM for Groups provides just-in-time membership or ownership of selected Microsoft Entra security groups and Microsoft 365 groups.
- Each area controls a different type of privileged access. Activating a Microsoft Entra ro does not automatically activate an Azure resource role or group membership.

EXAM FOCUS - First determine whether the scenario involves a directory role, Azure RBAC role, or group membership.

PIM for Microsoft Entra Roles



- PIM can manage built-in and custom Microsoft Entra administrative roles. Examples include User Administrator, Authentication Administrator, Conditional Access Administrator, and Global Administrator.

- An administrator can make a user eligible for a role. The user does not receive the ro permissions until they activate the assignment.

- Role settings determine the activation requirements. Different roles can have differen requirements for MFA, approval, justification, ticket information, and maximum activation duration.

- Privileged Role Administrator is commonly used to manage Microsoft Entra role assignments and PIM settings. Permanent active assignments remain possible but should be limited to exceptional requirements.

EXAM FOCUS - First determine whether the scenario involves a directory role, Azure RBAC role, or group membership.

PIM for Azure Resource Roles



- PIM can govern built-in and custom Azure RBAC roles. Examples include Reader, Contributor, Owner, Virtual Machine Contributor, and Role Based Access Control Administrator.

- The role assignment applies at an Azure scope. The scope can be a management gr subscription, resource group, or individual resource.

- An eligible user activates the Azure role only when elevated access is required. The can select an activation duration up to the maximum configured by the administrator.

EXAM FOCUS - First determine whether the scenario involves a directory role, Azure RBAC role, or group membership.

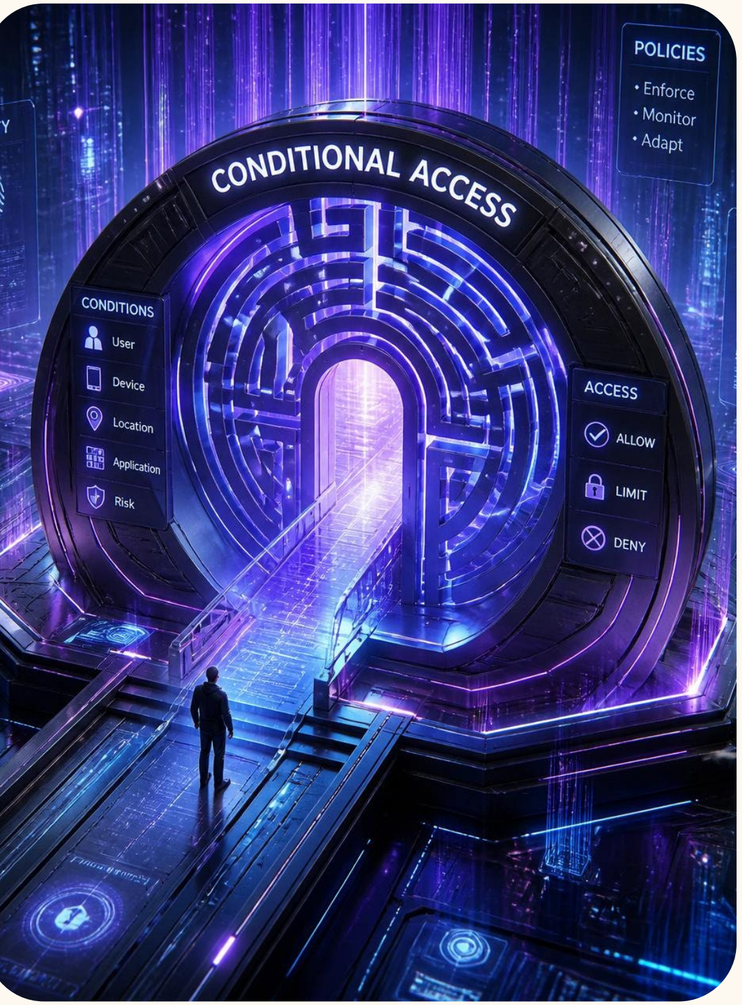
Assignment Type and Assignment Duration



- **Assignment type** determines whether activation is required. An assignment can be configured as either eligible or active.
- **Assignment duration** determines how long the assignment exists. It can be permanent or limited by specific start and end dates.
- **Permanent eligible** means the user remains eligible indefinitely but must activate the role whenever access is needed.
- **Time-bound eligible** means the user can activate the role only during a defined assignment window. This is useful for contractors, temporary projects, and short-term administrative responsibilities.

EXAM FOCUS - Do not confuse whether activation is required with how long the assignment exists.

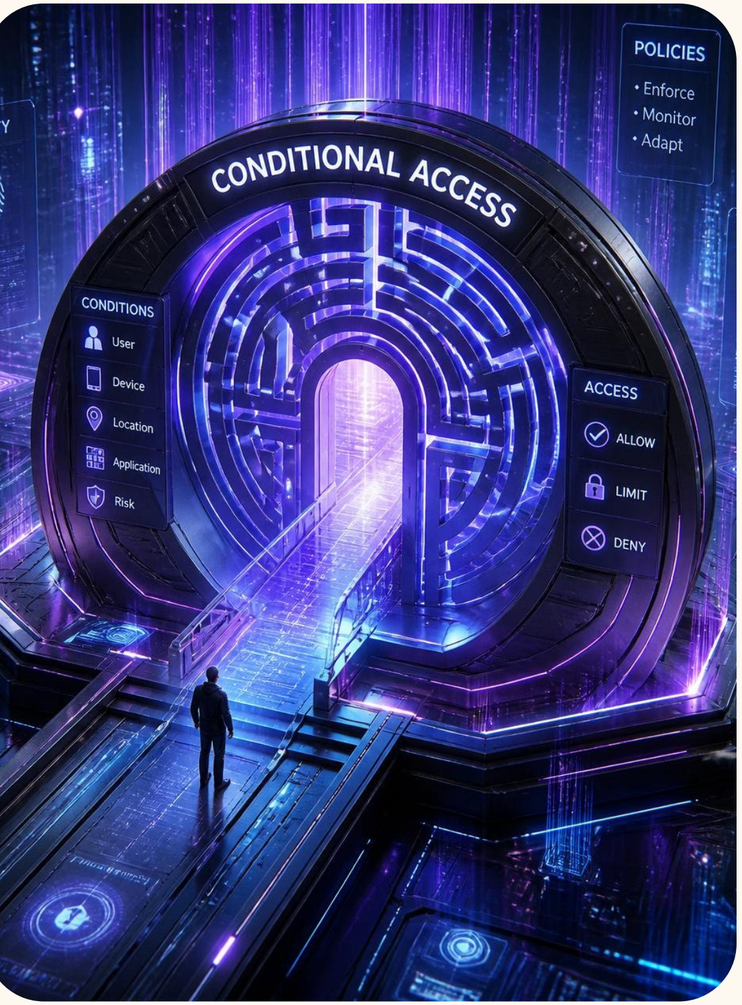
What Is Conditional Access?



- Microsoft Entra Conditional Access is a policy-based access control engine. It evaluates identity, application, device, location, risk, and other contextual signals before determining whether access should be allowed.
- Conditional Access operates through if-then decisions. If the configured assignments and conditions are satisfied, Microsoft Entra applies the specified grant controls or session controls.
- Conditional Access is evaluated after the initial authentication request. It can require additional verification, restrict the session, or block access before the requested resource is made available.
- Multiple Conditional Access policies can apply to the same sign-in. The user must satisfy the combined requirements of all applicable policies.

EXAM FOCUS - Conditional Access does not grant application permissions.
It controls the conditions under which an existing access request is allowed or blocked.

The Three Parts of a Conditional Access Decision



- Who or what is requesting access? The policy identifies the users, groups, directory roles, guests, workload identities, or supported agent identities that are included or excluded.

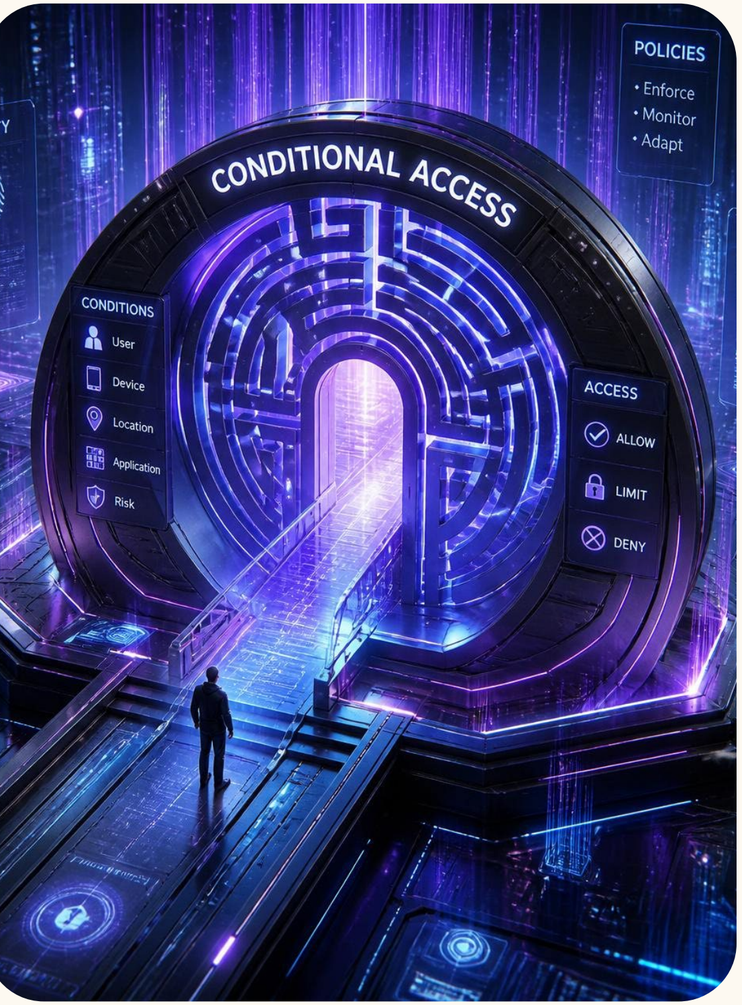
- What resource is being accessed? The policy can target Microsoft 365, Azure management, enterprise applications, individual cloud applications, user actions, or authentication contexts.

- Under what conditions is access requested? Microsoft Entra can evaluate signals suc location, device platform, device compliance, client application, authentication flow, ar calculated risk.

- What should happen? The policy can block the request, require additional grant controls, or apply restrictions to the resulting session.

EXAM FOCUS - Break each scenario into assignments, target resources and conditions, and access controls.

Targets, conditions, controls



- Policies can include all users or selected users and groups. Group targeting is normally easier to manage when many users require the same access requirements.
- Target resources identify what the user or workload is attempting to access. A policy c protect one application, several selected applications, or all resources.
- Location conditions evaluate the network location associated with the sign-in. Named locations can represent trusted IP ranges, selected countries or regions, or network locations used by an organization.
- Deviceplatform conditions can distinguish between Windows, macOS, Linux, iOS, Android, and other supported platforms.
- Device signals can indicate whether a device is registered, Microsoft Entra joined, hyb joined, or marked compliant by Microsoft Intune.

EXAM FOCUS - A requirement based on calculated sign -in risk or user risk normally requires Microsoft Entra ID P2.

What Is Azure Key Vault?



- Azure Key Vault is a managed service for protecting sensitive application and cryptographic information. It centralizes secrets, encryption keys, and certificates in a controlled Azure service.
- Applications retrieve protected values when they run. Credentials do not need to be embedded permanently in source code, configuration files, deployment scripts, or container images.
- Microsoft Entra ID authenticates users, applications, and managed identities that request access to a vault.
- Authorization determines which operations the authenticated identity can perform. Azure RBAC can separate administrators who manage objects from applications that only consume existing values.

EXAM FOCUS - Key Vault protects sensitive values, but an identity still requires both network reachability and appropriate data -plane permissions.

Secrets, Keys, and Certificates



- Secrets store sensitive text or binary values. Common examples include passwords, connection strings, API keys, tokens, and application configuration values.

- Keys support cryptographic operations. Applications can request encryption, decryptio signing, signature verification, key wrapping, and key unwrapping without receiving the protected private key material.

- Certificates manage X.509 certificates and their lifecycle. Key Vault can create or impo certificates and support renewal through configured certificate issuers.

EXAM FOCUS - Password or connection string → Secret
Encryption or signing operation → Key
TLS or identity certificate → Certificate

Key vault roles



- **Key Vault Secrets Officer** can perform data plane operations on secrets. The role can create, read, update, delete, recover, back up, and restore secrets.
- **Secrets Officer** cannot manage Azure RBAC permissions. Granting access remains separate from managing the secret lifecycle.
- **Key Vault Secrets User** can read existing secret contents and metadata. It is suitable for applications or users that need to consume a stored value but should not change it.
- **Key Vault Crypto Officer** manages the lifecycle of cryptographic keys. The role can create, import, update, rotate, delete, recover, back up, and restore keys.
- **Key Vault Crypto User** uses existing keys for cryptographic operations. Supported operations include encryption, decryption, signing, verification, key wrapping, and unwrapping.

EXAM FOCUS - Create and manage secrets → Key Vault Secrets Officer
Read existing secret values → Key Vault Secrets User

Key vault roles



- **Key Vault Reader** provides visibility into vault and object metadata. It can list object names, versions, properties, enabled status, and expiration information.
- **Key Vault Reader** cannot read sensitive secret values or protected private key material. This makes it useful for inventory, auditing, monitoring, and troubleshooting.
- **Key Vault Contributor** manages the Key Vault resource through the control plane. It can configure the vault but cannot read or manage the sensitive objects stored inside it.
- **Key Vault Contributor** cannot create Azure RBAC role assignments. A separate access management role is required to assign Key Vault data plane roles.

EXAM FOCUS - View object names and metadata only → Key Vault Reader

Manage the vault resource, not its contents → Key Vault Contributor

Application Identity



- Applications frequently need to access protected resources without a user being present. Background services, automation jobs, APIs, virtual machine workloads, and scheduled processes cannot depend on an employee completing an interactive sign-in.
- A workload identity allows the application to authenticate independently. Microsoft Entra ID can identify the application, issue an access token, and provide a traceable identity for security logs and access decisions.
- Permissions can be assigned directly to the application identity. This prevents the application from inheriting all the permissions of a developer, administrator, or other human account.
- Separate application identities support least privilege. Each workload can receive only the roles and API permissions required for its specific operations.

EXAM FOCUS - An unattended production application should normally authenticate as a workload identity, not by using a developer's personal account.

Registering an Application



- An application must be registered when it needs to integrate with the Microsoft identity platform. Registration establishes the identity configuration and trust relationship used during authentication.
- The registration records important application information. This can include the application name, supported account types, redirect URIs, required API permissions, exposed scopes, app roles, and credentials.
- Microsoft Entra ID assigns an application or client ID. This globally unique value identifies the application when it requests authentication or access tokens.
- The application can be configured as single-tenant or multitenant. A single-tenant application is intended for one organization, while a multitenant application can be made available in additional Microsoft Entra tenants.

EXAM FOCUS - App registrations is where developers define how an application integrates with Microsoft Entra ID.

The Application Object



- The application object is the main definition or blueprint of the application. It describes how Microsoft Entra ID should issue tokens and how the application participates in authentication.
- An application has one application object located in its home tenant. Even a multitenan application has only one application object.
- The application object can contain redirect URIs, required API permissions, exposed A scopes, app roles, branding, and supported account types.
- Confidential client credentials are associated with the application registration. These may include certificates, client secrets, or federated identity credentials.

EXAM FOCUS - The application object defines the application; it is not the tenant -specific object through which local access is normally managed.

What Is a Managed Identity?



- A managed identity is a special type of service principal provided for supported Azure resources. It allows a workload running on that resource to authenticate to Microsoft Entra ID.
- Azure manages the underlying credential. Administrators and developers do not receiv or store the password, secret, or private key used by the identity.
- Managed identities can request access tokens for services that support Microsoft Entra authentication. Examples include Azure Key Vault, Azure Storage, Azure SQL Databa and supported custom applications.
- Creating the identity does not automatically grant resource access. An administrator must still assign the required Azure RBAC role, API permission, or service-specific authorization.

EXAM FOCUS - A managed identity removes the need to manage credentials; it does not remove the need to configure authorization.

System-Assigned Managed Identity



- A system-assigned managed identity is enabled directly on a supported Azure resource. Examples include an Azure virtual machine, App Service, Function App, Logic App, or another supported service.
- The identity is dedicated to one Azure resource. It cannot be shared with another resource.
- Its lifecycle is tied to the parent resource. When the Azure resource is deleted, Azure automatically deletes the corresponding managed identity service principal.
- The identity is convenient when one workload needs its own independent permissions. For example, one virtual machine can receive permission to read a secret from one Key Vault.

EXAM FOCUS - One Azure resource needs its own identity, deleted with that resource → System-assigned managed identity.

User-Assigned Managed Identity



- A user-assigned managed identity is created as a separate Azure resource.
- Its lifecycle is independent of the resources that use it. Deleting a virtual machine, App Service, or other workload does not automatically delete the identity.
- The same user-assigned identity can be attached to multiple supported Azure resources. Those workloads can then authenticate with the same identity and share its assigned permissions.
- User-assigned identities support preauthorization. Administrators can create the identity and grant permissions before deploying the compute resources that will use it.

EXAM FOCUS - Multiple Azure resources need to share one identity, or the identity must survive resource replacement → User-assigned managed identity.

Delegated Permissions



- Delegated permissions are used when an application acts on behalf of a signed-in user. The permission values are also called OAuth scopes.
- Interactive user sign-in is required. The resulting access token represents both the application and the signed-in user.
- Effective access is limited by two boundaries: the delegated permission granted to the application and the permissions already held by the signed-in user.
- Common delegated permissions include User.Read, Mail.Read, Files.Read, and Calendars.Read. Some can be consented to by users, while others require administrator consent

EXAM FOCUS - Signed-in user present and the application acts for that user → Delegated permission.

Application Permissions



- Application permissions are used when an application calls an API using its own identi
  They are also known as app roles or app-only permissions.
- No signed-in user is required. This makes them suitable for background services, automation, scheduled processes, integrations, and daemon applications.
- The application's access is determined by the application permission that has been granted. It is not limited by a signed-in user's personal access.
- Application permissions can provide broad tenant-wide access. For example, User.Read.All may allow an application to read users throughout the organization.

EXAM FOCUS - Background process with no user sign-in → Application permission

Application Consent



- Consent is the process through which a user or administrator approves an application's requested access to a protected API.
- User consent applies to supported delegated permissions. Whether users can consent depends on tenant user consent settings, the application, publisher status, and the permissions requested.
- Administrator consent can approve delegated permissions on behalf of users across the organization.
- Application permissions require administrator consent because the application operates without a signed-in user and can potentially access broad organizational data.

EXAM FOCUS - User cannot approve a requested permission → Admin consent may be required
App-only Microsoft Graph access → Admin consent is required

User Consent Policies



- Microsoft Entra administrators can control whether normal users are allowed to conser to applications.
- User consent can be disabled, permitted broadly, or limited to applications from verifie publishers and permissions classified as low impact.
- App consent policies provide more granular conditions for determining which applications and permissions users can approve.
- When users cannot provide consent, the admin consent workflow allows them to submit a request for administrator review.

EXAM FOCUS - Allow users to request approval without granting consent themselves → Configure the admin consent workflow

What Are Azure Resource Locks?



- Azure resource locks protect important Azure resources from accidental deletion or modification. They add an additional control that must be removed before a blocked management operation can succeed.
- Locks can be applied at the subscription, resource group, or individual resource scope. They are not assigned at the management group scope.
- A lock applies regardless of the user's Azure RBAC permissions. Even an Owner cannot complete an operation blocked by the lock unless the lock is removed first.
- Resource locks are intended to prevent accidental administrative actions. They are commonly applied to production databases, networking resources, shared services, and other resources that would cause significant disruption if changed or deleted.

EXAM FOCUS - Having Owner or Contributor access does not allow a user to bypass an existing resource lock.

Delete and Read-Only Locks



- Delete, represented as `CanNotDelete`, allows authorized users to read and modify the resource but prevents them from deleting it.
- Read-only, represented as `ReadOnly`, allows authorized users to read the resource but prevents management-plane updates and deletions.
- Read-only is more restrictive than Delete. It can block operational tasks such as changi configuration, scaling a service, restarting a virtual machine, or creating related control plane resources.
- A Delete lock is normally preferred when administrators must continue managing the resource but accidental deletion must be prevented.

EXAM FOCUS - Prevent deletion but permit configuration changes → Delete lock
Prevent deletion and management -plane changes → Read -only lock.

Lock Scope and Inheritance



- A lock applied to a subscription is inherited by its resource groups and resources. This creates broad protection across the subscription.
- A lock applied to a resource group is inherited by the resources contained in that resource group.
- A resource-level lock protects only that individual resource. It is appropriate when other resources in the resource group should remain unrestricted.
- Child resources inherit locks from their parent scope. Adding another lock at the child level cannot make an inherited parent lock less restrictive.
- Deleting a resource group also deletes the resources inside it. A Delete lock on the resource group therefore protects the group and prevents the group-level deletion operation.

EXAM FOCUS - To protect every resource in one resource group, apply the lock to the resource group, rather than creating a separate lock on every resource.

What Is Azure Policy?



- Azure Policy is an Azure governance service used to enforce organizational standards and assess compliance at scale.
- Azure Policy evaluates Azure resources and management actions against defined business rules. A resource can be marked compliant, marked non-compliant, modified, supplemented, or blocked depending on the policy effect.
- Common use cases include restricting deployment locations, enforcing required tags, limiting resource types or SKUs, requiring diagnostic settings, and checking security configurations.
- The Policy compliance dashboard provides an aggregated view of compliance. Administrators can drill down from an assignment or initiative to the policy definition and individual non-compliant resource.

EXAM FOCUS - Control who can perform an action → Azure RBAC
Control which resource configurations are permitted → Azure Policy

The Main Components of Azure Policy



- Policy definition: Contains the business rule that determines which resources are evaluated and the effect applied when the condition is matched.
- Policy assignment: Applies a policy definition or initiative to a selected scope, such as management group, subscription, resource group, or individual resource.
- Policy parameters: Allow one reusable definition to accept different values when assigned, such as different approved locations or required tag names.
- Policy effect: Determines what Azure Policy does when the resource matches the polic condition, such as auditing, denying, modifying, or deploying a related resource.

EXAM FOCUS - Definition = the rule
Assignment = where the rule applies
Effect = what happens when the rule matches

Built-In and Custom Policy Definitions



- Azure provides built-in policy definitions for common governance requirements. Examples include restricting allowed locations, limiting virtual machine SKUs, requiring tags, and auditing security settings.
- Built-in definitions are maintained by Microsoft. Organizations can assign and parameterize them but do not edit the original built-in definition.
- Custom definitions are created when the available built-in definitions do not satisfy a specific organizational requirement.
- A custom definition is stored at either a subscription or management group location. It can be assigned only to that location or to scopes beneath it in the hierarchy.

EXAM FOCUS - A custom policy that must be assigned across several subscriptions should be defined at a management group containing those subscriptions.

Important Azure Policy Effects



- Audit allows the request but records the resource as non-compliant when it does not satisfy the policy.
- Deny blocks a create or update request that would produce a non-compliant resource.
- Modify adds, changes, or removes supported properties during resource creation or update and can remediate supported existing resources.
- DeployIfNotExists deploys a related resource or configuration when the required item does not exist, such as a diagnostic setting.

EXAM FOCUS - Identify non-compliance without blocking → Audit
Stop non-compliant deployment → Deny
Correct a property → Modify

Locks, Azure Policy, and Azure RBAC



- Azure RBAC controls authorization. It determines which identities can perform specific Azure management or data operations at a selected scope.
- Azure Policy controls governance and compliance. It evaluates whether resources and actions satisfy organizational rules.
- Resource locks protect specific resource scopes from deletion or modification. They ar straightforward safeguards rather than full compliance rules.
- The controls can operate together. A user may have Contributor access, be limited by Deny policy, and still be prevented from deleting a resource by a Delete lock.

EXAM FOCUS - Who can manage the resource? → Azure RBAC
Which configurations are permitted? → Azure Policy
Prevent accidental deletion or changes? → Resource lock

What Are Azure Management Groups?



- Azure management groups provide a governance scope above Azure subscriptions.
- They allow organizations to arrange multiple subscriptions into a hierarchy for centralized access, policy, and compliance management.
- Azure Policy assignments made at a management group are inherited by descendant management groups, subscriptions, resource groups, and resources.
- Azure RBAC role assignments can also be made at management group scope and inherited by descendant subscriptions and resources.

EXAM FOCUS - Apply one policy or Azure role assignment across several subscriptions → place the subscriptions under a management group and assign the control there.

SC-500 | Microsoft Certified: Cloud and AI Security Engineer Associate

SECTION 2

Secure storage, databases, and networking



INSTRUCTOR
ALAN RODRIGUES

CloudXeus Technology Services

Azure Storage Accounts



- An Azure storage account is a top-level Azure resource that contains storage data objects such as blobs, file shares, queues, and tables. It acts as the main administrativ boundary for these storage services.

- Every storage account creates a unique namespace. Applications use service endpoin based on the storage account name to access Blob, File, Queue, or Table data over H or HTTPS.

- Important settings such as data redundancy, encryption, networking, access control, monitoring, and lifecycle management are configured through the storage account.

- A general-purpose v2 storage account is recommended for most scenarios because it supports Blob Storage, Azure Files, Queue Storage, and Table Storage together with current Azure Storage features.

EXAM FOCUS - Remember that the storage account is the administrative and security boundary, while containers, blobs, file shares, queues, and tables are data resources inside it.

Azure Storage Services



- Blob Storage stores object data such as documents, images, videos, application logs, backups, installation files, and analytics datasets.
- Azure Files provides managed file shares that applications and operating systems can access by using protocols such as SMB or NFS.|
- Queue Storage stores messages that allow application components to communicate asynchronously without requiring both components to be available at the same time.
- Table Storage provides a scalable NoSQL key-value store for structured data that does not require the relationships and schema of a traditional relational database

EXAM FOCUS - Identify the correct service from the data requirement: objects use Blob, shared folders use Files.

Authorizing Access to Storage Data



- Every request to secured Azure Storage data must be authorized. Authorization determines whether the requesting user or application has permission to perform the requested data operation.
- Microsoft Entra identities can receive permissions through Azure RBAC roles. This is t preferred method for users, applications, service principals, and managed identities.
- Storage account access keys support Shared Key authorization, while a Shared Acces Signature provides limited delegated access through a signed token.
- Network access and authorization are separate checks. A client might have the correct role or SAS token but still be blocked by the storage firewall.

EXAM FOCUS - Successful storage access normally requires both an allowed network path and a valid authorization method.

Accessing Data with Storage Account Keys



- Each storage account has two access keys. Either key can be used to sign requests through Shared Key authorization and to generate service or account SAS tokens.
- An access key provides extremely broad privileges. Anyone possessing a valid key ca effectively authorize access to the data in the storage account.
- Two keys support key rotation. An application can temporarily use one key while the other key is regenerated and updated in the application configuration.
- Access keys should be protected, rotated, and preferably stored in Azure Key Vault. Microsoft recommends using Microsoft Entra authorization and disabling Shared Key access where application compatibility permits.

EXAM FOCUS - Choose access keys only when an application requires Shared Key authentication. For identity -based and least -privilege access, prefer Microsoft Entra ID and Azure RBAC.

Shared Access Signatures



- A Shared Access Signature, or SAS, is a signed token that delegates access to selecte storage resources without revealing the storage account key to the client.
- The token can define the accessible resource, permitted operations, start time, expiry time, required protocol, and optionally an allowed IP address or range.
- Azure supports user delegation SAS, service SAS, and account SAS. Service and acco SAS tokens are signed using an account key, while a user delegation SAS uses Micros Entra credentials.
- A SAS is commonly used when an external user or application needs temporary direct access to upload or download data but should not receive a permanent identity or storage account key.

EXAM FOCUS - For Blob Storage, prefer a user delegation SAS because it is secured through Microsoft Entra credentials rather than directly through the storage account key.

Stored Access Policies



- A stored access policy defines permissions, start time, and expiry time on a blob container, file share, queue, or table.
- A service SAS can reference the policy instead of storing every access restriction direc inside the SAS token. Multiple service SAS tokens can therefore inherit the same polic settings.
- Administrators can modify the policy to change permissions or expiry settings for all associated SAS tokens. The policy can also be deleted, renamed, or expired to revoke associated access.
- A maximum of five stored access policies can be configured on an individual container table, queue, or file share.

EXAM FOCUS - Stored access policies work with service SAS tokens.

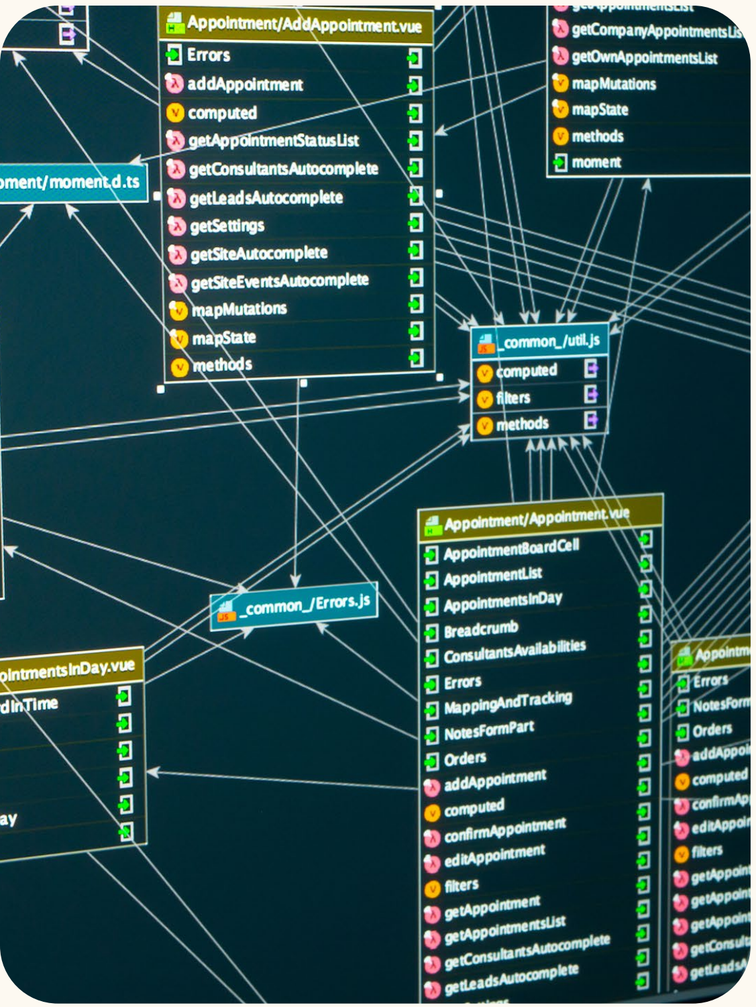
Important Storage Roles



- Storage Blob Data Reader provides read-only access to blob containers and blob data. The principal can list and open blobs but cannot upload, modify, or delete them.
- Storage Blob Data Contributor provides read, write, and delete access to blob containe and blobs. It is appropriate for applications that must upload or modify data.
- Storage Account Contributor permits management of storage accounts and access to account keys. The role contains no direct data actions, but the retrieved keys can provide broad Shared Key access.
- Reader provides read only visibility into the storage account’s management settings but does not grant permission to access the contents of blobs.

EXAM FOCUS - Read blob data: Storage Blob Data Reader.
Modify blob data: Storage Blob Data Contributor.
Manage the account: Storage Account Contributor.

Azure SQL Database: A Managed Database Service



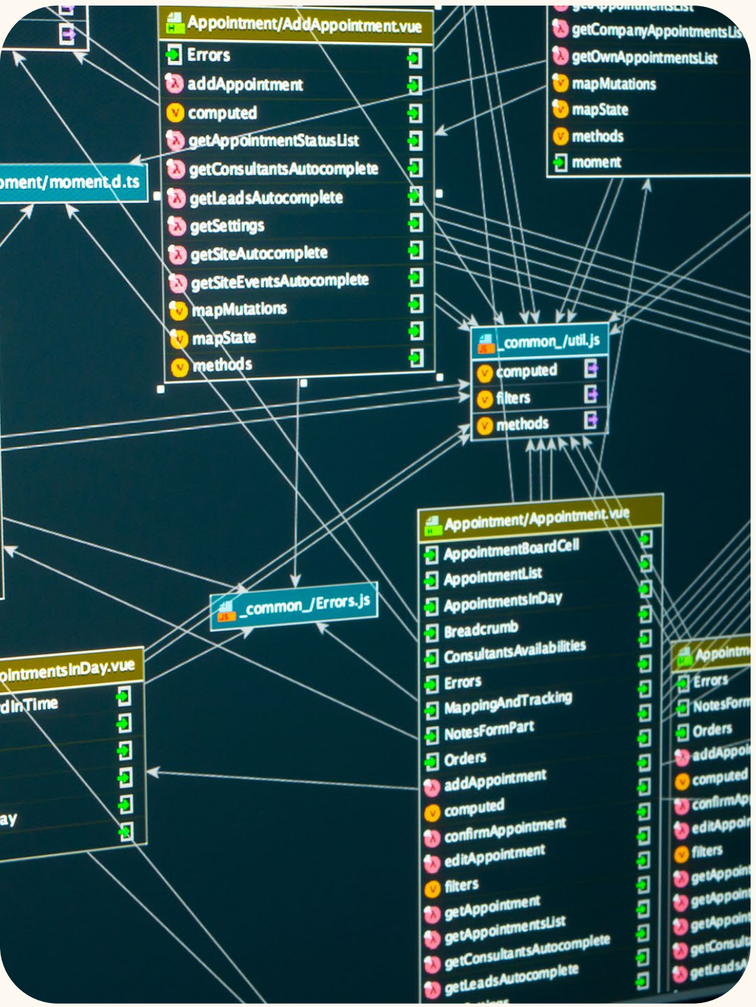
- Azure SQL Database is a fully managed platform as a service database built on the Microsoft SQL Server database engine. It is designed for applications that need a relational database without managing the underlying server infrastructure.

- Microsoft manages operational responsibilities such as the operating system, database engine patching, upgrades, automated backups, availability, and much of the platform monitoring.

- Customers remain responsible for configuring database access, authentication, networking, auditing, data protection, performance, and the permissions assigned to users and applications.

EXAM FOCUS - Azure SQL Database is a PaaS service. Microsoft manages the underlying infrastructure, while the customer configures identities, permissions, network access, and database security.

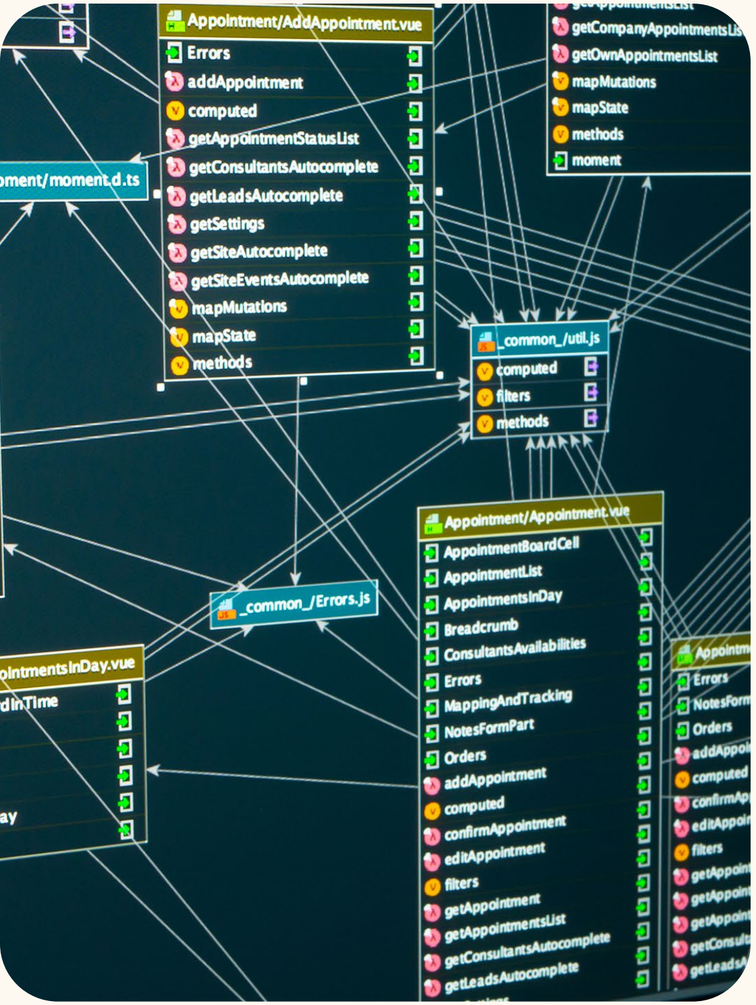
Security Layers for Azure SQL Database



- Network security determines whether the client is permitted to reach the logical server by using firewall rules, virtual network rules, service endpoints, or private endpoints.
- Authentication verifies the identity connecting to the database. Azure SQL supports SQ authentication and Microsoft Entra authentication.
- Authorization determines what the authenticated identity may do by using database users, roles, object permissions, and other SQL authorization controls.
- Monitoring and protection can include auditing, Microsoft Defender for SQL, vulnerability assessment, encryption, and security alerts.

EXAM FOCUS - A valid username or token is not sufficient when the network path is blocked. Azure SQL evaluates network access, authentication, and authorization as separate security controls.

Authentication Methods in Azure SQL



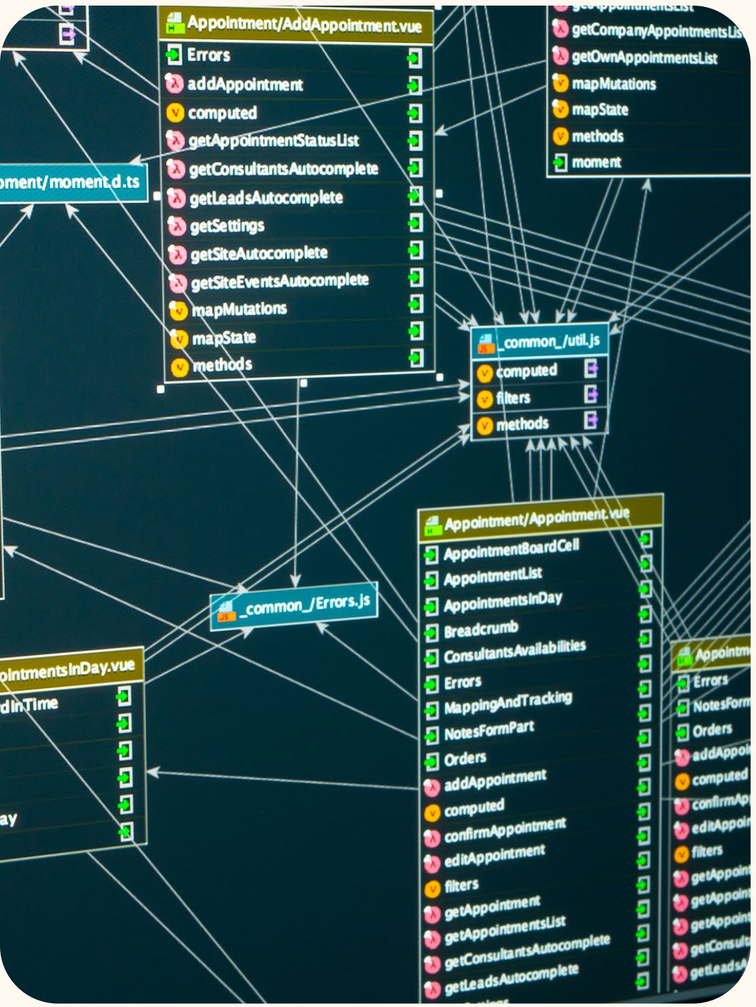
- SQL authentication uses a SQL login or contained database user together with a password managed within the SQL database platform.

- Microsoft Entra authentication uses identities maintained in Microsoft Entra ID, such a users, groups, service principals, and managed identities.

- With Microsoft Entra authentication, the client obtains an access token from Microsoft Entra ID and presents the token to Azure SQL during the connection process.

EXAM FOCUS - SQL authentication validates a database -managed password.
Microsoft Entra authentication validates an identity token
issued by Microsoft Entra IDs.

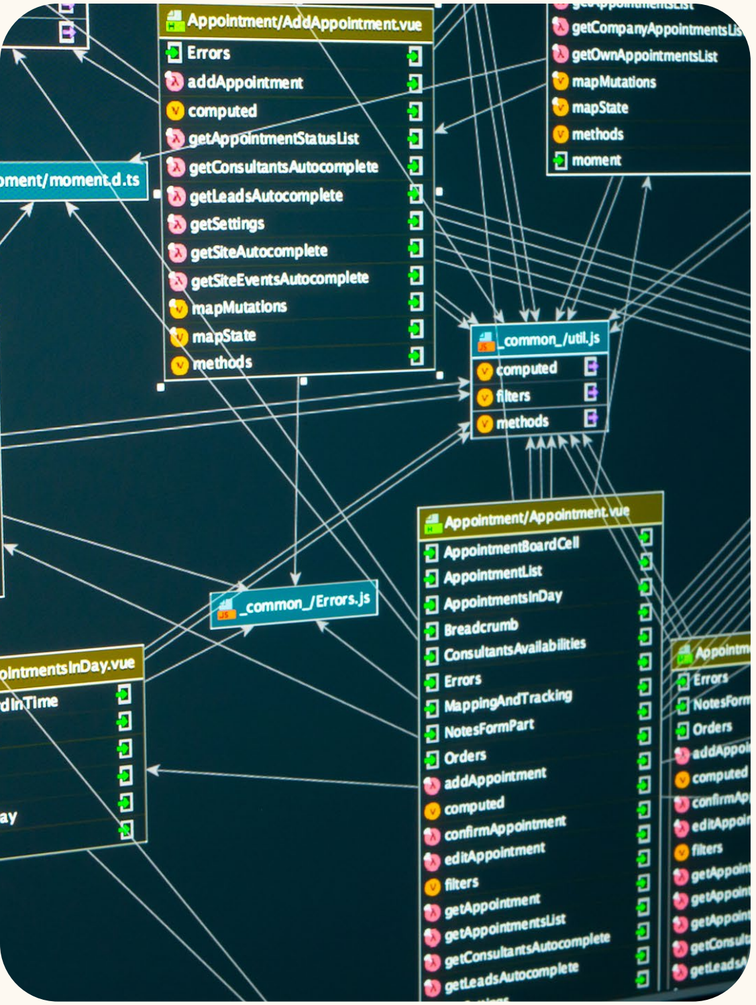
Microsoft Entra-Only Authentication



- Microsoft Entra-only authentication prevents clients from connecting to the logical server or its databases by using SQL authentication credentials.
- Existing SQL logins and users are not automatically deleted, but their SQL authentication credentials cannot be used while Microsoft Entra-only authentication remains enabled.
- A Microsoft Entra administrator must be configured before the setting can be enabled for the logical server.

EXAM FOCUS - When a requirement states that only Microsoft Entra identities may connect, enable Microsoft Entra -only authentication.
Merely configuring an Entra administrator is insufficient.

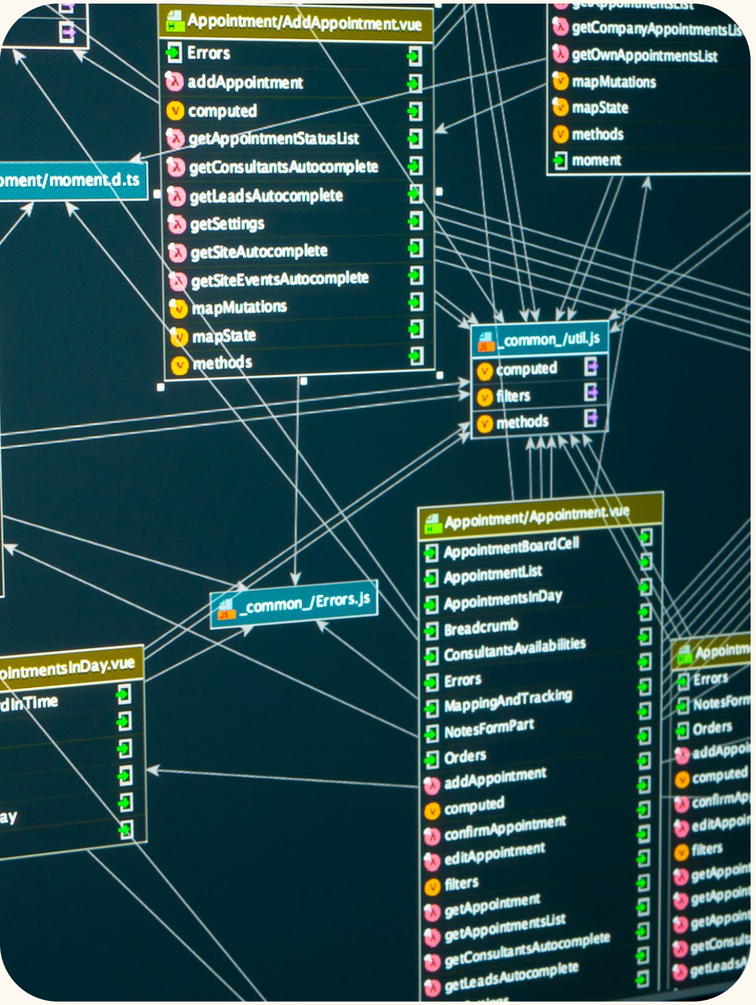
Azure SQL Firewall



- Azure SQL Database uses firewall controls to protect the public endpoint of the logical SQL server from unauthorized network connections.
- Server-level firewall rules can permit connections from selected public IPv4 addresses or address ranges and apply to all databases hosted by the logical server.
- The option to allow Azure services and resources provides broad access from Azure-based source addresses and should not be confused with granting an identity permission to the database.
- A client permitted by the firewall must still authenticate successfully and possess the required database permissions before it can access data.

EXAM FOCUS - The SQL firewall controls where connections may originate. Authentication and database permissions determine who may connect and what that identity may do.

What Is Azure SQL Auditing?

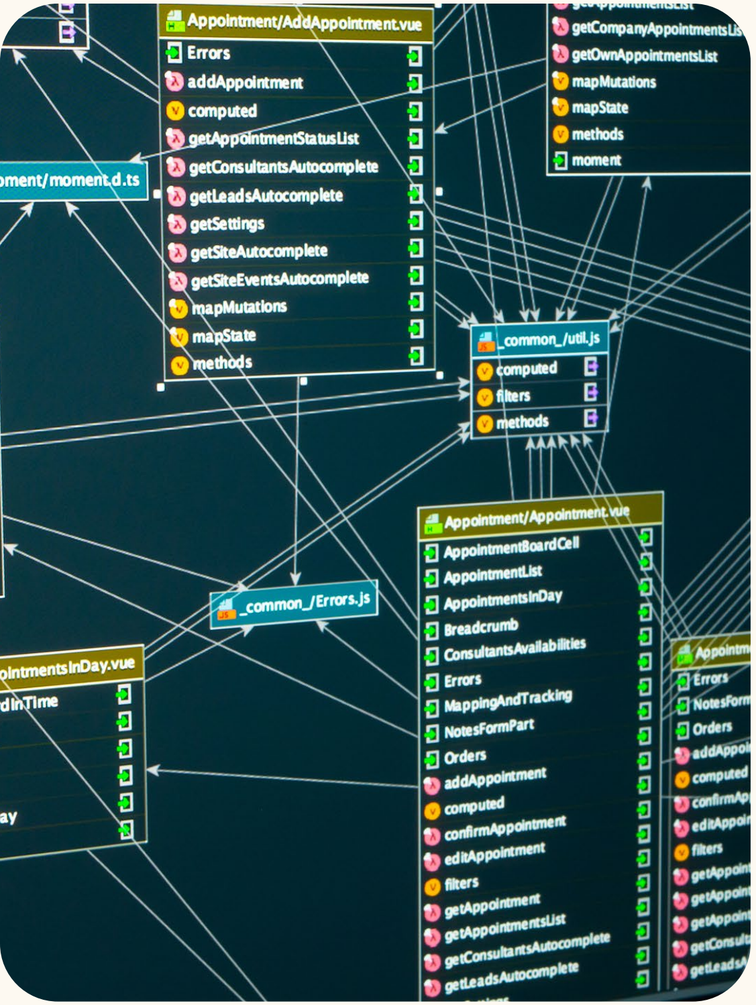


- Azure SQL auditing tracks selected database events and writes them to an audit destination for later review and investigation.
- Audit records can capture activities such as database queries, authentication events, permission changes, schema operations, and other configured database actions.
- Auditing helps organizations investigate suspicious behavior, understand database activity, retain an audit trail, and support compliance requirements.
- Azure SQL Database can send audit records to an Azure Storage account, a Log Ana workspace, or Azure Event Hubs.

EXAM FOCUS - Auditing records database activity. It does not block malicious activity or automatically guarantee regulatory compliance.

.

Sending Audit Logs to Log Analytics



- A Log Analytics workspace provides a centralized location for collecting, retaining, searching, and analyzing Azure monitoring and security data.
- When Log Analytics is selected as the auditing destination, Azure creates or uses a diagnostic setting that sends the SQL auditing event category to the workspace.
- Security administrators can query the audit data, filter events by user or action, investigate failed sign-ins, and correlate SQL activity with logs from other Azure resources.
- Log Analytics can also support workbooks, dashboards, alert rules, and broader secu investigations using Azure Monitor capabilities.

EXAM FOCUS - Select a Log Analytics workspace when audit records must be centrally queried, investigated, correlated, or used to create monitoring alerts.

.

SC-500 | Microsoft Certified: Cloud and AI Security Engineer Associate

SECTION 4

Manage and monitor security posture



INSTRUCTOR
ALAN RODRIGUES

CloudXeus Technology Services

Microsoft Defender for Cloud



- Microsoft Defender for Cloud is a CNAPP that combines security posture management with workload threat protection across Azure, AWS, GCP, and hybrid environments.
- CSPM identifies configuration weaknesses, exposed resources, vulnerabilities, and oth security risks before they are exploited.
- Defender workload plans add protection for resources such as servers, storage, databases, containers, and Key Vault.
- Think of Defender for Cloud as assess → prioritize → protect → detect → respond

EXAM FOCUS - Remember that Defender for Cloud combines security posture management with workload protection; CSPM identifies and prioritizes risk, while Defender plans protect specific workloads.

Microsoft Defender for Cloud



- Foundational CSPM provides core posture management capabilities such as recommendations, Secure Score, and the Microsoft Cloud Security Benchmark.
- Defender CSPM adds advanced capabilities including attack paths, Cloud Security Explorer, risk prioritization, and agentless scanning.
- Defender workload plans are enabled according to the resource type that requires threat protection rather than enabling one universal workload plan.
- For full Defender CSPM functionality, including agentless scanning, ensure the required permissions are available when the plan is enabled.

EXAM FOCUS - Distinguish Foundational CSPM from Defender CSPM: advanced capabilities such as attack path analysis, Cloud Security Explorer, risk prioritization, and agentless scanning require Defender CSPM.

Microsoft Defender for Cloud



- The Microsoft Cloud Security Benchmark (MCSB) is the foundational Microsoft security standard used to evaluate cloud resources.
- A security recommendation identifies a resource that doesn't meet an assessed securit requirement and normally includes remediation guidance.
- Recommendations can affect Secure Score, helping teams prioritize improvements tha reduce security risk.
- Additional security standards can be assigned when an organization needs to assess resources against different frameworks.
- The Regulatory compliance dashboard maps assessed resources and recommendatio to controls in supported standards.

EXAM FOCUS - Remember that the Microsoft Cloud Security Benchmark provides security recommendations; recommendations identify what should be remediated, while Secure Score helps prioritize security improvements.

Microsoft Defender for Databases



- Defender for Databases provides threat detection for supported database workloads and generates alerts for suspicious or anomalous database activity.
- Choose the Defender plan that matches the database technology, not simply the fact that the workload contains a database.
- Azure Database for PostgreSQL and MySQL → Microsoft Defender for Open-Source Relational Databases.
- Azure SQL, SQL Server on machines, Cosmos DB, and open-source relational databases have distinct protection options and can be priced separately

EXAM FOCUS - Select the Defender plan based on the database technology: Azure Database for PostgreSQL and MySQL use Microsoft Defender for Open -Source Relational Databases..

Microsoft Defender for Storage



- Defender for Storage adds threat detection capabilities to Azure Storage, including on-upload and on-demand malware scanning.
- Malware scanning can expose results through blob index tags, Defender for Cloud alerts, Event Grid, and Log Analytics.
- Event Grid is the preferred option when scan results must immediately trigger automated processing such as a Function App or Logic App.
- Storage-account-level settings can override subscription-level Defender for Storage settings when an individual account needs a different malware-scanning configuration.

EXAM FOCUS - For automated processing of malware scan results, think Event Grid; for a different malware-scanning limit on one storage account, override the subscription-level Defender for Storage settings at the account level.

Microsoft Defender for Containers



- Defender for Containers protects supported Kubernetes and container environments across the workload lifecycle.
- Capabilities include vulnerability assessment, Kubernetes security posture, runtime threat detection, and security recommendations.
- Agentless and sensor-based capabilities serve different purposes; understand which features require deployment to the cluster.
- Container findings can also contribute context to attack paths and Cloud Security Explorer.

EXAM FOCUS - Remember that Defender for Containers combines posture and vulnerability information with runtime threat protection; not every container security capability is purely agentless.

Microsoft Defender for Servers



- Defender for Servers provides security capabilities for Windows and Linux machines running in Azure and supported hybrid/multicloud environments.
- Azure Arc brings supported on-premises and non-Azure servers into Azure management so Defender for Cloud can protect them.
- Enabling the appropriate Defender for Servers plan can integrate supported servers wi Microsoft Defender for Endpoint without onboarding each server manually.
- Server protection can include vulnerability assessment, EDR integration, JIT access, a File Integrity Monitoring depending on the plan and configuration.

EXAM FOCUS - For Azure Arc-enabled or hybrid servers that need Defender for Endpoint protection with minimal per-server administration, enable the appropriate Defender for Servers plan in Defender for Cloud.

Microsoft Defender for Servers



- Vulnerability assessment identifies known vulnerabilities and security weaknesses on protected machines and presents remediation recommendations.
- Defender CSPM can use agentless machine scanning to inspect supported machine di without installing another scanning agent.
- Agentless scanning can discover plaintext credentials, private keys, tokens, and other exposed secrets on supported machines.
- Microsoft Defender for Endpoint provides EDR telemetry, behavioral detection, investigation, and response for onboarded servers.
- When a third-party antivirus must remain primary on Windows Server, configure Microsoft Defender Antivirus in passive mode while retaining Defender for Endpoint ED capabilities.

EXAM FOCUS - To discover plaintext secrets, SSH keys, and other exposed credentials on supported machines without installing another agent, use agentless machine scanning through Defender CSPM or Defender for Servers Plan 2.

Microsoft Defender for Servers



- JIT reduces the attack surface by keeping management ports such as RDP and SSH closed until legitimate access is requested.
- A request specifies the permitted source IP, port, and access duration, after which access is automatically removed.
- JIT requires Defender for Servers Plan 2 and supported network controls such as an N or Azure Firewall.
- Use JIT when the requirement is to reduce exposure from permanently open management ports, not to scan the VM for vulnerabilities.

EXAM FOCUS - JIT is a Defender for Servers Plan 2 capability that reduces exposure by opening management ports only for an approved source, port, and limited period of time.

Microsoft Defender for Cloud



- Attack Path Analysis identifies exploitable chains of connected security risks that could allow an attacker to reach critical resources.
- It uses the Cloud Security Graph to correlate exposure, vulnerabilities, identities, permissions, relationships, and lateral movement opportunities.
- Cloud Security Explorer lets security teams query the Cloud Security Graph to proactively search for risks across their environment.
- Queries can combine properties such as internet exposure, vulnerabilities, permissions, identities, sensitive data, and resource relationships.
- Asset Inventory provides a centralized view of connected cloud resources across supported Azure, AWS, and GCP environments.

EXAM FOCUS - Attack Path Analysis finds predefined exploitable paths; Cloud Security Explorer is used when you need to build your own graph-based query to investigate relationships and risks.

What is Microsoft Sentinel?



- Microsoft Sentinel is Microsoft's cloud-native SIEM and SOAR platform for collecting, detecting, investigating, and responding to security threats.
- It ingests data from Microsoft, Azure, on-premises, multicloud, and third-party sources into a Log Analytics workspace.
- Sentinel helps a SOC move through the security lifecycle: collect → detect → investigate → respond.
- Core capabilities include data connectors, analytics rules, incidents, hunting, workbooks, automation, and playbooks.

EXAM FOCUS - Remember that Microsoft Sentinel is both a SIEM and a SOAR platform: it centralizes security data and supports automated response.

The Microsoft Defender Portal



- Microsoft Sentinel is available in the Microsoft Defender portal, giving a more unified SecOps experience across SIEM and XDR.
- The Defender portal centralizes investigation across incidents, alerts, identities, device cloud resources, hunting, and response workflows.
- Microsoft has made it clear that Sentinel’s long-term home is the Defender portal, and the Azure portal experience is being phased out.
- This matters operationally because analysts increasingly work in a unified incident queue and investigation experience.

EXAM FOCUS - Know that Microsoft Sentinel now has a unified experience in the Microsoft Defender portal, which is the strategic portal going forward.

Windows Security Events via AMA



- The modern way to collect Windows security events is Windows Security Events via AMA, using the Azure Monitor Agent.
- Data collection is controlled through a Data Collection Rule (DCR), which defines what events are collected and where they are sent.
- AMA is the supported agent model for new deployments and gives more flexible, targeted collection than older methods.
- In lab terms, students should understand the relationship between VM → AMA → DCR → Log Analytics workspace → Sentinel.

EXAM FOCUS - If the question asks for a supported agent -based method for collecting Windows Security events from VMs, think Windows Security Events via AMA.

Collect Syslog Events from Linux Servers



- Linux Syslog collection in Sentinel commonly uses the Azure Monitor Agent and a Data Collection Rule.
- DCRs help control which Syslog facilities and severities are collected before the data is written to the workspace.
- This is important because filtering before ingestion can reduce noise and lower ingestio costs.
- Syslog collection is conceptually similar to Windows event collection, but the source an event format differ.

EXAM FOCUS - If the requirement says filter Syslog before data is written to the workspace and reduce ingestion cost, the answer is a Data Collection Rule.

Collect Windows Forwarded Events (WEF) and Common Event Format (CEF)



- Windows Event Forwarding (WEF) is used to forward Windows events from source systems to a central collector before they are ingested.
- CEF is a common format used by many third-party security devices and products for security event ingestion.
- In Microsoft Sentinel, CEF and Syslog ingestion can be implemented through supported connectors and AMA-based collection patterns.
- The exam may test whether you can distinguish Windows event forwarding from third-party device log ingestion.

EXAM FOCUS - WEF is for forwarded Windows events, while CEF is a standard format commonly used by third-party security devices and appliances.

Microsoft Sentinel RBAC Roles



- Common Sentinel roles include Microsoft Sentinel Reader, Responder, Contributor, an Playbook Operator, each granting different operational capabilities.
- A Reader can view data, a Responder can manage incidents, and a Contributor has broader configuration permissions.
- Some scenarios also require a Microsoft Entra role, such as Directory Reader, especia for guest users and enriched investigation needs.
- The attached question pattern is important: assigning incidents required Directory Reader + Microsoft Sentinel Responder.

EXAM FOCUS - To assign and manage incidents, think Microsoft Sentinel Responder; in some guest -user scenarios, Directory Reader is also required.

Alerts and Incidents in Microsoft Sentinel



- Alerts are generated by analytics or connected products; incidents group related alerts into a manageable investigation case.
- Incident settings determine how alerts are grouped and how the investigation workload is presented to analysts.
- Incident handling includes assignment, classification, severity review, status changes, comments, and ownership.
- In the Defender portal, incidents can appear in a unified incident queue with broader crossdomain context.

EXAM FOCUS - Alerts are individual detections; incidents are the investigation container that groups related alerts for analyst workflow.

Automatic Response with Automati Rules and Playbooks



- Automation rules in Sentinel are used to automatically update, assign, tag, or trigger actions when incidents are created or updated.
- Playbooks are Logic Apps-based workflows used to perform response actions such as notifications, enrichment, blocking, or ticket creation.
- If an organization uses an unsupported ITSM platform, a playbook is typically the right way to create service tickets automatically.
- The attached question pattern is key: if the goal is to assign all new incidents to Tier 1 and flag them for triage, create an automation rule.

EXAM FOCUS - Automation rules manage Sentinel incident workflow; playbooks perform workflow actions such as enrichment, notification, and third-party ticketing.